

Real-time questions during class – Claper

- You can use Claper for asking questions during the lecture.
- We will answer your questions at the end of the lecture.
- Go to:
<https://claper.fi.muni.cz/e/pb177>



M U N I
F I

MITRE ATT&CK

Resource Development, Initial Access

PB177 Cyber Attacks

October 1, 2026

Jan Vykopal

Lab 1 wants you

- This week, we are starting Lab 2 in your lab sessions.
- **Some of you have not completed the first lab.**
- If you are not proficient enough in Podman and Linux commands used in the first lab, we recommend practicing them too.
- **The first homework covering topics of Lab 1 and 2 will be assigned next week.**

MITRE ATT&CK Enterprise tactics

The adversary's tactical goal: the reason for performing an action.
15 tactics in total:

1. **Reconnaissance** – gather information useful for planning future operations
2. **Resource Development** – establish resources for supporting operations
3. **Initial Access** – get into the target network
4. **Execution** – run malicious code
5. **Persistence** – maintain foothold
6. **Privilege Escalation** – gain higher-level permissions
7. **Stealth** – to hide and conceal actions, appearing as normal behavior

MITRE ATT&CK Enterprise tactics

- 8. Defense Impairment** – break security tooling so defenders can't see or trust what's happening
- 9. Credential Access** – steal account names and passwords
- 10. Discovery** – figure out the target environment
- 11. Lateral Movement** – move through the environment
- 12. Collection** – gather data of interest to the attacker's goal
- 13. Command and Control** – communicate with compromised systems to control them
- 14. Exfiltration** – steal data
- 15. Impact** – manipulate, interrupt, or destroy systems and data

Selected MITRE ATT&CK techniques

Resource Development

Resource Development

- Consists of techniques that involve adversaries **creating, purchasing, or compromising/stealing resources that can be used to support targeting.**
- Such resources include infrastructure, accounts, or capabilities.
- These information are **used in other phases of the lifecycle**, such as:
 - using purchased domains to support Command and Control,
 - using email accounts for phishing as a part of Initial Access,
 - stealing code signing certificates to help with Defense Evasion.
- Some techniques **can be detected.**
- **Mitigation is difficult**, techniques are performed **outside of the scope of enterprise defenses.**

Resource Development – techniques

- Acquire Access
- Acquire Infrastructure
- Compromise Accounts
- Compromise Infrastructure
- Develop Capabilities
- Establish Accounts
- Obtain Capabilities
- Stage Capabilities

See <https://attack.mitre.org/tactics/TA0042/>.

Acquire Access

- Purchasing or acquiring **an existing access** to a target system or network.
- A variety of **online services** are available to sell access to previously compromised systems.
- Footholds to compromised systems may take a variety of forms, such as **planted backdoors** (web shells) or established access via **external remote service** (VPN, VNC, RDP, SSH).
- In contrast to developing or obtaining own initial access capabilities, an adversary can potentially **reduce the resources required to gain a foothold** on a target network **and focus their efforts on later stages of compromise**.
- **Cannot be detected nor mitigated** (takes place outside the visibility of the target organization).

Acquire Infrastructure

- **Buying, leasing, renting, or obtaining infrastructure** that can be used during targeting.
- Infrastructure solutions include **physical or cloud servers, domains, and third-party web services.**
- Use of these infrastructure solutions allows adversaries **to stage, launch, and execute operations.**
- **Examples:** renting a botnet, setting up Google Drive to host malicious downloads, using GitHub to host malware linked in spearphishing e-mails.
- **Cannot be easily detected nor mitigated.**

Acquire Infrastructure II

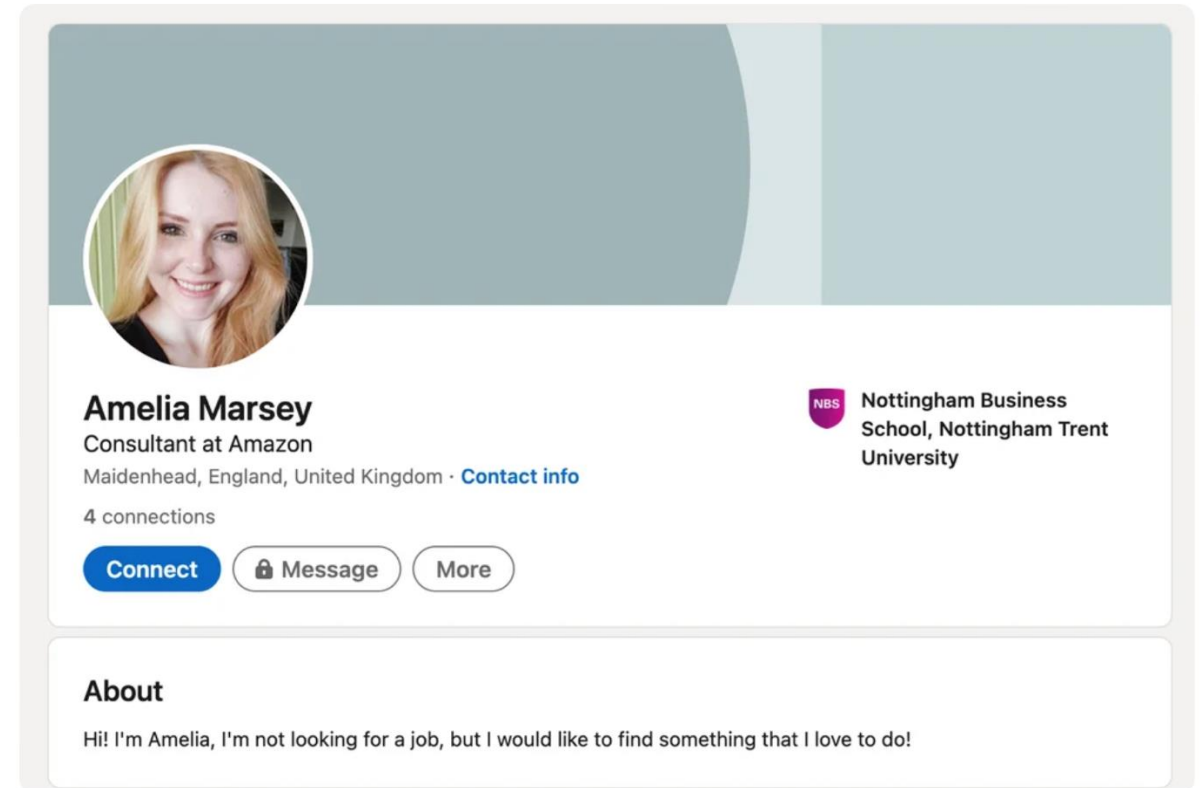
- Subtechniques:
 - Domains
 - DNS Server
 - Virtual Private Server
 - Server
 - Botnet
 - Web Services
 - Serverless
 - Malvertising
- See <https://attack.mitre.org/techniques/T1583/> for more.
- Related technique: [Compromise Infrastructure](#) – compromising existing infrastructure

Establish Accounts

- Creating and cultivating accounts with services that can be used during targeting.
- Accounts are used to **build a persona to further operations**.
- Persona development consists of the development of **public information, presence, history and appropriate affiliations**.
- Applied to social media, website, or other publicly available information that could be **referenced and scrutinized for legitimacy** over the course of an operation using that persona or identity.

Establish Accounts II – Example

- **EXOTIC LILY** has established social media profiles to mimic employees of targeted companies.
- Attackers sent spear phishing emails under the pretext of a business proposal, such as seeking to outsource a software development project or an information security service.



One of the fake social media profiles created by EXOTIC LILY

Establish Accounts III

- Another example: creating credible personas that connect, linked, followed, “friended” target victims for cyber espionage
- Detection: only monitoring social media activity related to your organization
- Mitigation: difficult, outside of the scope of enterprise defenses and controls.
- Related technique: [Compromise Accounts](#) (compromising existing accounts rather than creating new)
- See <https://attack.mitre.org/techniques/T1585/> for more.

Develop Capabilities and Obtain Capabilities

- **Capabilities** are malware, software (including licenses), exploits, code-signing and SSL/TLS certificates, and information relating to vulnerabilities.
- These techniques are **building capabilities in-house (Develop Capabilities)** or **purchasing, freely downloading, or stealing them (Obtain Capabilities)**.
- **Cannot be detected nor mitigated** (takes place outside the visibility of the target organization).
- See <https://attack.mitre.org/techniques/T1587/> and <https://attack.mitre.org/techniques/T1588/>.

Stage Capabilities

- **Uploading, installing, or setting up capabilities** that can be used during targeting.
- The capabilities may be **staged on infrastructure** that was previously purchased/rented by the adversary (Acquire Infrastructure) or was otherwise compromised by them (Compromise Infrastructure).
- Capabilities may also be staged on **web services**, such as GitHub or Pastebin, or on **Platform-as-a-Service (PaaS)** offerings that enable users to easily provision applications.

Stage Capabilities II

- Staging helps in initial access and post-compromise behaviors, such as:
 - staging web resources for a link target to be used with spearphishing,
 - uploading malware or tools to a location accessible to a victim network,
 - installing a previously acquired SSL/TLS certificate to use to encrypt command and control traffic.
- **Cannot be detected nor mitigated** (takes place outside the visibility of the target organization).
- See <https://attack.mitre.org/techniques/T1608/> for more.

Selected MITRE ATT&CK techniques

Initial Access

Initial Access

- Consists of techniques that use various entry vectors to **gain initial foothold within a network**.
- Examples: targeted spearphishing, exploiting a vulnerability on a public-facing web server.
- It may allow for **continued access** (using valid accounts of external remote services) or may be **limited-use** (due to changing passwords).

Initial Access – techniques

- Content Injection
- Drive-by Compromise
- Exploit Public-Facing Application
- External Remote Services
- Hardware Additions
- Phishing
- Replication Through Removable Media
- Supply Chain Compromise
- Trusted Relationship
- Valid Accounts

See <https://attack.mitre.org/tactics/TA0001/> for more.

Content Injection

- Gaining access and continuously communicating with victims by **injecting malicious content into systems through online network traffic.**
- Adversaries **compromise data-transfer channels** where they can **manipulate traffic and/or inject their own content.**
- Example: injecting content into DNS, HTTP, and SMB replies to redirect specifically-targeted victims to [a fake Windows Update page to download malware.](#)

Content Injection II

- Detection: **unusual network traffic** (known malicious payloads, content obfuscation, and exploit code), endpoint: abnormal behaviours of browser **processes**, suspicious **files written to disk**.
- Mitigation: **traffic encryption**, restriction of web-based content (blocking download or execution of uncommon file types)
- See <https://attack.mitre.org/techniques/T1659/> for more.

Drive-by Compromise

- **Gaining access to a system through a user visiting a website over the normal course of browsing.**
- User's web browser is typically targeted for exploitation.
- Typical drive-by compromise process:
 1. A user visits a website hosting the **adversary-controlled content**.
 2. Scripts automatically execute, but the **user may be required to assist** by enabling scripting or active website components and ignoring warning dialog boxes.
 3. **Exploit code** is delivered to the **browser**.
 4. Adversary gets **code execution on the user's system**.

Drive-by Compromise II

- Detection: abnormal **behaviours of browser processes**, inspect **URLs** for potentially known-bad domains or parameters, **new files written to disk**, **new network connections to untrusted hosts** or **delivering known malicious scripts**.
- Mitigation: application **isolation and sandboxing**, restriction of web content (adblockers, script blocking)
- **Difficult for attackers**, browser escape is needed, but these vulnerabilities are scarce.
- See <https://attack.mitre.org/techniques/T1189/> for more.

Exploit Public-Facing Application

- Attempt to **exploiting a weakness in an Internet-facing host** or system to initially access a network.
- The weakness in the system can be a **software bug, a temporary glitch, or a misconfiguration**.
- Exploited applications are often **web servers**, but can also include databases (SQL), other services (such as SMB or SSH), network device administration and management protocols (SNMP), and any other system with Internet accessible open sockets.

Exploit Public-Facing Application II

- In contrast to Drive-by Compromise, it will **not** give access to systems on the internal network, but to external systems that may be in a DMZ.
- **Very common and frequently used technique.**
- Tools: [Hydra](#), [Medusa](#), [Ncrack](#), [Metasploit](#), [sqlmap](#), [wpscan](#), [Burp](#), [nikto](#), ...
- Detection: **web application firewalls** may detect improper inputs in **logs**, **deep packet inspection** can reveal injection strings or known payloads.
- Mitigation: software **updating**, **network segmentation**, application **isolation**, using **least privilege for service accounts**, **vulnerability scanning**.
- See <https://attack.mitre.org/techniques/T1190/> for more.

External Remote Services

- Leveraging **external-facing remote services** to initially access and/or persist within a network.
- Remote services such as **VPNs, VNC** and other access mechanisms allow users to connect to internal enterprise network resources from external locations.
- Attacker usually must use **valid credentials of existing accounts**, but access may be gained through an exposed service that does **not require authentication**.

External Remote Services II

- Detection:
 - collect **authentication logs** and **analyze** for unusual access patterns, windows of activity, and access outside of normal business hours,
 - monitor for **network traffic of remote services**, especially originating from **unknown or unexpected devices**.
- Mitigation: **disable** unnecessary remotely available services or limit access to them through centrally managed concentrators (VPNs), use **multi-factor authentication**, deny direct remote access to internal systems
- See <https://attack.mitre.org/techniques/T1133/> for more.

Hardware Additions

- **Introducing** computer **accessories**, **networking hardware**, or other computing devices **into a system or network** that can be used as a vector to gain access.
- Existing products can be leveraged with capabilities such as **passive network tapping**, **network traffic modification**, **keystroke injection**, **kernel memory reading** via DMA, addition of **new wireless access** to an existing network.

Hardware Additions II – examples

USB Rubber Ducky



LAN Tap Pro



Hardware Additions III

– Detection:

- **Configuration management databases (CMDB)** and other **asset management systems** may help with the detection of computer systems or network devices that should not exist on a network.
- Monitor for **newly constructed drives** or other related events associated with computer hardware and other accessories.
- Monitor for network **traffic originating from unknown/unexpected hardware devices**.
- **Mitigation:** establish **network access control policies** (device certificates, 802.1x), **block unknown devices** and accessories.
- See <https://attack.mitre.org/techniques/T1200/> for more.

Phishing I

- **Sending messages to gain access to victim systems.**
- Electronically delivered social engineering.
- **Very common and frequently used technique.**
- **Spearphishing** – phishing targeting a specific individual, company, or industry.
- Non-targeted phishing is typically delivered using mass malware spam campaigns (check your inbox/spambox).

Phishing II

Subtechniques:

- Spearphishing **Attachment** – malicious attachment enabling access to victim systems.
- Spearphishing **Link** – emails contain links to download malware.
- Spearphishing **via Service** – sending messages through social media services, personal webmail, and other non-enterprise controlled services.
- Spearphishing **Voice** – manipulating a user into providing access to systems through a phone call or other forms of voice communications.

Tools: [Evilginx](#), [GoPhish](#)

Phishing III – Example

- Delivered by e-mail, found in spambox.
- Contains a link, which points to a site that some security vendors flagged as malicious according to Virustotal.
- It seems that attacker used Spearphishing Link subtechnique.
- However, it can also be a false positive detection of a spam.

**50lbs in 61 Days: New No-Exercise ‘Skinny Pill’ Melts
Why Every Judge On Shark Tank Backed This Product!**

**READ THE EXCLUSIVE
ARTICLE NOW!**



Tweets	Following	Followers	Likes	Lists
161K	1,183	2.25M	1,960	3

Your Stomach Will Shrink Fast

Phishing IV – Detection

- Similar to Phishing for information (see the Recon tactic)
- Monitoring application logs and network traffic for:
 - suspicious email activity (numerous accounts receiving messages from a single unusual/unknown sender),
 - references (URL) to uncategorized or known-bad sites,
 - call logs from corporate devices to identify patterns of potential voice phishing,
 - **monitor for newly constructed files from a phishing messages to gain access to victim systems.**

Phishing IV – Mitigation

- **Antivirus/Antimalware** – quarantine suspicious files.
- **Audit** – scans of systems, permissions, insecure software, insecure configurations.
- **Network Intrusion Prevention** – scan and remove malicious email attachments or links.
- **Restrict Web-Based Content** – monitoring/blocking certain websites or attachment types.
- **Software Configuration** – use anti-spoofing and email authentication mechanisms to filter messages based on the sender domain (SPF) and integrity of messages (DKIM).
- **User training**
- See <https://attack.mitre.org/techniques/T1566/> for more.

Replication Through Removable Media

- **Copying malware to removable media and taking advantage of Autorun features** when the media is inserted into a system and executes.
- Manual manipulation of the media, modification of systems used to initially format the media, or modification of the media's firmware itself.
- This technique is also used for the Lateral Movement tactic.
- Famous example: [Stuxnet](#) used this for spreading in air-gapped networks.
- Common example:
 - A smartphone is connected to a system.
 - It may appear similar to a USB-connected disk drive.
 - If malware that is compatible with the connected system is on the mobile device, the malware could infect the machine.

Replication Through Removable Media II

- Detection – monitor for
 - newly constructed drive letters or mount points to removable media (Drive Creation).
 - new files and unexpected files accessed on removable media (File Access/Creation).
 - newly executed processes that execute from removable media after it is mounted or when initiated by a user (Process Creation).
- Mitigation:
 - Block unsigned/untrusted executable files from running from USB removable drives (Behavior Prevention on Endpoint).
 - Disable Autorun if it is unnecessary. Restrict removable media at an organizational policy level (Disable or Remove Feature or Program).
 - Limit the use of USB devices and removable media within a network (Limit Hardware Installation)
- See for <https://attack.mitre.org/techniques/T1091/> more.

Supply Chain Compromise

- **Manipulation of products or product delivery mechanisms prior to receipt by a final consumer** for the purpose of data or system compromise.
- Can impact any component of hardware or software.
- Adversaries focus on malicious additions to legitimate software in software distribution or update channels.
- Targeting may be specific to a desired victim set.
- Popular open-source projects that are used as dependencies in many applications may also be targeted as a means to add malicious code to users of the dependency.

Supply Chain Compromise II

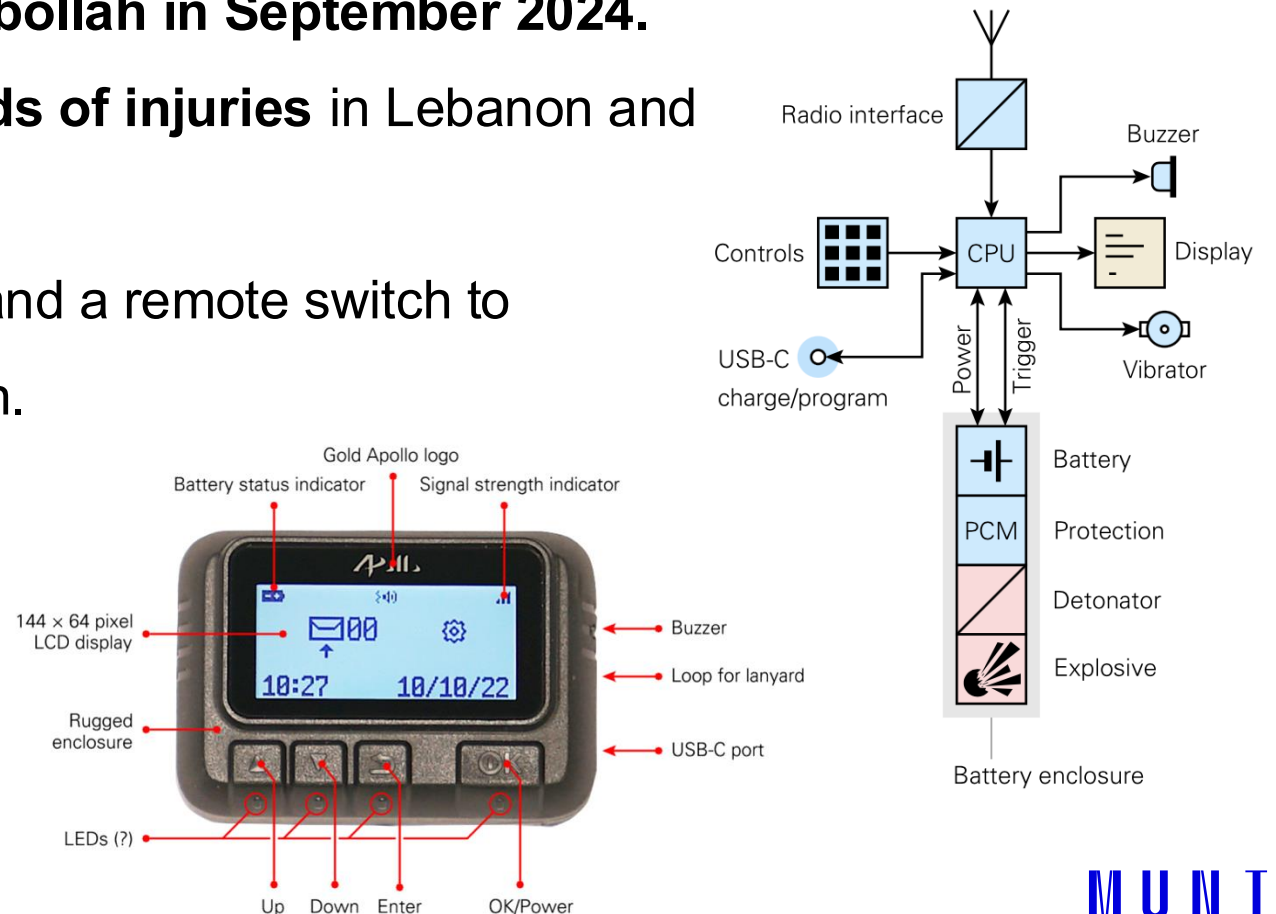
Subtechniques:

- Compromise Software Dependencies and Development Tools
- Compromise Software Supply Chain
- Compromise Hardware Supply Chain

- Example of compromise of HW supply chain with fatalities:
Operation Grim Beeper (see next slide)

Example: Operation Grim Beeper

- Explosions of pagers belonging to Hezbollah in September 2024.
- Resulted in **tens of deaths and thousands of injuries** in Lebanon and Syria.
- Israel added 3 grams of PETN explosive and a remote switch to thousands of pagers ordered by Hezbollah.
- [“Death by notification.”](#)
- More details:
[CNN](#), [Washington Post](#), [CryptoMuseum](#)



Supply Chain Compromise III

– Detection:

- verify distributed binaries (hash checking),
- scan downloads for malicious signatures,
- test software and updates prior to deployment and check potential suspicious activity.

– Mitigation:

- developers should be cautious when **selecting third-party libraries** to integrate into their application, developers should **lock software dependencies to specific versions** rather than pulling the latest version,
- use secure methods to boot a system and verify the integrity of the operating system and loading mechanisms,

Supply Chain Compromise IV

– Mitigation:

- Require developers to pull from internal repositories containing verified and approved packages rather than from external ones.
- Check unused dependencies, unmaintained and/or previously vulnerable dependencies, unnecessary features, components, files, and documentation.
- Continuously monitor vulnerability sources, use automatic and manual code review tools.

– See <https://attack.mitre.org/techniques/T1195/> for more.

Trusted Relationship

- **Breaching or otherwise leveraging organizations who have access to intended victims.**
- Access through trusted third-party relationship abuses an existing connection that may not be protected or receives less scrutiny than standard mechanisms of gaining access to a network.
- Examples of these relationships: IT services contractors, managed security providers, infrastructure contractors (e.g. HVAC, elevators, physical security).
- Concrete example: administrator permissions for MS Office 365 delegated to a MS partner serving the organization

Trusted Relationship II

– Detection:

- Monitor logs for unexpected actions taken by any delegated administrator accounts.
- Monitor for newly constructed logon behaviour, correlate other security systems with login information.
- Analyze traffic patterns and flows from a trusted entity.

– Mitigation:

- Require MFA for all delegated administrator accounts.
- Network segmentation – isolate infrastructure components that do not require broad network access.
- Manage accounts and permissions used by parties in trusted relationship.

– See <https://attack.mitre.org/techniques/T1199/> for more.

Valid Accounts

- **Obtaining and abusing credentials of existing accounts** as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion.
- Compromised credentials may be used to **bypass access controls** placed on various resources on systems within the network.
- Adversaries may abuse inactive accounts (such as accounts of individuals who are no longer part of an organization).
- Examples:
 - VPN and SSH credentials abused by many APT groups.
 - [Ember Bear used default usernames and passwords for access to IP cameras](#)

Valid Accounts II

Subtechniques:

- Default Accounts
- Domain Accounts – accounts of Active Directory Domain Services
- Local Accounts
- Cloud Accounts

Valid Accounts – Detection

- Monitor for an attempt by a user that may obtain and abuse credentials of existing accounts (e.g. check `/var/log/auth.log` at Linux hosts).
- Correlate other security systems with login information (e.g., a user has an active login session but has not entered the building or does not have VPN access).
- Look for suspicious account behavior across systems that share accounts (e.g. accounts logged in at odd times or outside of business hours).

Valid Accounts – Mitigation

- Block logins from non-compliant devices or from outside **defined organization IP ranges**.
- Disable legacy authentication, which does not support **MFA**.
- Ensure that applications do not store **sensitive data or credentials insecurely** (e.g., plaintext credentials in code, published credentials in repositories).
- Apply **password policies** (change default passwords, use keys, disallow password reuse).
- **Audit the domain and local accounts and their permission levels**.
- Regularly audit user accounts for activity and **deactivate any that are no longer needed**.
- **User training** – train users how to use MFA and report suspicious push notifications.
- See <https://attack.mitre.org/techniques/T1078/> for more.

Invitation to Incident Response Simulation

- Think you can outsmart a real-world threat actor? Prove it!
- **What:** ThreatSpace Cyber Drill, a hands-on Capture The Flag (CTF) competition where you step into the shoes of a Security Operations Center (SOC) analyst.
- **When:** October 16, 2026, 11:00-12:00 CET
- Available only to universities participating in the Google.org Cybersecurity Seminars (such as Masaryk university).
- [Registration form](#)

Questions, answers, and feedback in Claper

- You can use Claper for asking questions during the lecture.
- We will answer your questions at the end of the lecture.
- Go to:
<https://claper.fi.muni.cz/e/pb177>
- **Please provide us with feedback:**
How can today's class be improved?



M U N I

F I

Feedback z Claperu 2025 pro 2026

- Možná více příkladů z reality, něco jako Hizbalah
- Dlhšie prednasky celkovo kde vieme prejsť viac vecí
- Jedine škoda, že nie je viac času kde je možné sa pozrieť bližšie na niektoré príklady ako to niektoré skupiny urobili/dokazali
- Bohužel nebol čas zapracovať pro 2026